

Local Privilege Escalation by Zywin UI misconfigured file ownership

report by: Dan Stephen B. Blanco, Zyphor OS Head Security

VULNERABILITY TYPE: Local Privilege Escalation CVE-2019-7656

SEVERITY: CVSS 7.8

AFFECTED ASSET: 1.0.0-r1-stable-release

A **Local Privilege Escalation** is possible when a privilege user executes the modified or Trojanized Zywin UI application

VULNERABILITY DESCRIPTION:

The Zywin UI application has a misconfigured file ownership set to normal user instead of root, which allows malicious software to modify the application's internal instruction and change its behavior.

Vulnerable Permission Configuration:

File: `/usr/bin/zywin-ui`

File Access: `-r-xr-xr-x 1 <normal_user> <normal_user> /usr/bin/zywin-ui`

STEPS TO REPRODUCE:

1. Executing the exploit file written by the Zyphor OS Head Security
 2. Writing `echo "<some texts>" > /usr/bin/zywin-ui`
-

PROOF OF CONCEPT:

for Malware attack possibility:

- The Exploit file (that represents as the malware) is sent to other platforms via Meta Messenger
- The Video Demo is sent to other platforms via Meta Messenger

Expected: `Shows additional window that shows Hacked, yup, pwned :<`

Actual: `Just shows`

IMPACT:

- Complete take over of the system.

EXPOSURE:

- Users files and possible stored credentials is exposed to adversary
-

REMEDIATION:

Always sets root as the file owner to custom Zyphor OS packages at `DEBIAN/postinst`

```
chown root:root /usr/bin/zywin-ui
```
